



INSTITUTO FEDERAL
Rio Grande do Sul

Banco de Dados II

Segurança em Banco de Dados

Prof. Dr. Edimar Manica
edimar.manica@ibiruba.ifrs.edu.br



Roteiro

- Técnicas para proteger os bancos de dados
- Esquemas para fornecer privilégios de acesso a usuários autorizados



Principal Bibliografia

- ELMASRI, Ramez; NAVATHE, Sham. Sistemas de banco de dados. 6.ed. São Paulo, SP: Pearson Education do Brasil, c2011. xviii, 788 p. ISBN 9788579360855.



Problemas relacionados à segurança

- Questões legais e éticas
 - Algumas informações são consideradas particulares e não devem ser acessadas legalmente por organizações ou pessoas não autorizadas
- Questões políticas em nível governamental ou institucional
 - Algumas informações são armazenadas pelo governo, instituição e/ou empresa, mas não devem ser divulgadas e/ou vendidas (ex: registros médicos, classificações de crédito)
- Questões relacionadas ao sistema
 - Níveis de sistema que determinadas funções de segurança devem ser impostas (ex: hardware, SO, SGBD)
- Categorias de acesso
 - Os dados e os usuários devem ser categorizados e possuir uma política de acesso por categoria



Consequências das Falhas de Segurança

- Perda de Integridade
 - O quê?
 - Mudanças não autorizadas feitas por atos intencionais ou acidentais
 - Resultado
 - Decisões imprecisas, errôneas ou fraudulentas
- Perda de disponibilidade
 - O quê?
 - Indisponibilidade de acesso aos dados por pessoa autorizada
 - Resultado
 - Atraso em tarefas, diminuição de vendas, perda de clientes, etc.
- Perda de confiabilidade
 - O quê?
 - Exposição não autorizada de dados confidenciais
 - Resultado
 - Ação legal contra a organização, constrangimento, perda da confiança pública



Medidas de Controle

- Controle de Acesso
- Controle de inferência
- Controle de fluxo
- Criptografia de dados



Medidas de Controle

- **Controle de Acesso**
- Controle de inferência
- Controle de fluxo
- Criptografia de dados



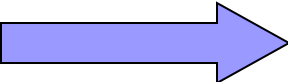
Objetivo

- proteger contra acessos mal intencionados
- controlar quais dados um usuário/grupo de usuários pode ter acesso
- controlar quais operações um usuário/grupo de usuários pode realizar sobre estes dados



Exemplo 01

- Em um sistema bancário, um funcionário precisa saber os dados dos clientes, mas apenas os que possuem conta poupança na agência **1899-6**



Cliente (#codCli, nome, endereco, codCidade)

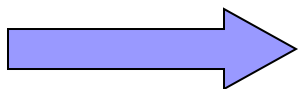
Agencia (#codAgencia, nome, descricao)

Poupança (# numConta, # codAgencia, # codCli, saldo)

Restrição de linhas

Exemplo 02

- Um funcionário de uma empresa deve ter acesso aos nomes dos funcionários e aos seus projetos, mas não deve ter acesso ao salário dos funcionários



Empregado (#codEmp, nome, categoria, salario)

Projeto (#codProj, tipo, descricao)

ProjetoEmpregado (# codProj, # codEmp, dataInicial, dataFinal)

Restrição de colunas



Administrador do Banco de Dados

- O DBA é o superusuário do BD, que pode tudo
 - alguns privilégios são exclusivos dele, como a *recuperação* do BD, a configuração de parâmetros do SGBD, etc.
 - concede/revoga privilégios de acesso aos outros usuários

user: postgres

Formas de acesso principais

- Nível de conta (usuário): o DBD pode dar permissões aos usuários para criar esquemas, modificar e criar tabelas, selecionar e manipular dados
 - Independente das relações do BD
- Nível de relação/visão: o DBA pode controlar o privilégio de acesso de cada usuário a relações ou visões específicas do BD
 - Para cada usuário podem ser dadas permissões de leitura (seleção), modificação e referência



Tipos de Autorização

- Leitura: permite apenas recuperar dados de uma relação
 - Permissão de SELECT
- Modificação: privilégios para inserir, alterar e excluir
 - Permissão de INSERT, UPDATE, DELETE
 - Para INSERT e UPDATE é possível restringir os atributos
- Referência: uma conta (de usuário) pode fazer referência a uma relação ao especificar restrições de integridade
 - Pode ser por atributo



SQL



SQL: Criando usuários

- Criando usuário com senha

CREATE USER nome_usuario **WITH PASSWORD** 'senha'

- Criando usuário com senha válida até 31/12/2018

CREATE USER nome_usuario **WITH PASSWORD** 'senha'
VALID UNTIL '2018-12-31'

- Criando usuário que pode criar bases de dados

CREATE USER nome_usuario **WITH PASSWORD** 'senha' **CREATEDB**

- Criando usuário que pode criar usuários

CREATE USER nome_usuario **WITH PASSWORD** 'senha' **CREATEUSER**



Concedendo privilégios

- Sintaxe nível de conta:

GRANT <lista de privilégios> **TO** <lista de usuários>

GRANT SELECT TO joao, maria, jose

- Sintaxe nível de relação:

GRANT <lista de privilégios> **ON** <nome da relação ou visão> **TO** <lista de usuários>

GRANT SELECT ON deposito **TO** joao, maria

GRANT UPDATE (saldo) ON deposito **TO** joao, maria

- Lista básica de privilégios:
 - SELECT, INSERT, UPDATE, DELETE



Controle de Acesso: Exemplos

- Exemplo 1: Em um sistema bancário, um funcionário precisa saber os dados dos clientes, mas apenas os que tem conta poupança na agência 1899-6

Cliente (codCli, nome, endereco, codCidade)

Agencia (codAgencia, nome, descricao)

Poupança (numConta, # codAgencia, # codCli, saldo)

- Solução: usar views**

```
CREATE VIEW vClientePoupancaAgencia as
SELECT c.codCli, c.nome, p.numConta
FROM cliente c
JOIN poupanca p ON c.codCli=p.cod_cli
WHERE p.codAgencia="1899-6"
```

GRANT select **ON** vClientePoupancaAgencia **TO** pedro



Exemplo

- Um funcionário de uma empresa deve ter acesso aos nomes dos funcionários e aos seus projetos, mas não deve ter acesso ao salário dos funcionários

```
CREATE VIEW vEmpregadoProjeto as
SELECT e.codEmp, e.nome, p.tipo, p.descricao,
       j.dataInicial, j.dataFinal
FROM empregado e
JOIN projetoEmpregado j ON e.codEmp=j.codEmp
JOIN projeto p ON j.codProj=p.codProj
```

- GRANT** select **ON** vEmpregadoProjeto **TO** carla



Empregado (codEmp, nome, categoria, ~~salario~~)
Projeto (#codProj, tipo, descricao)
ProjetoEmpregado (# codProj, # codEmp, dataInicial, dataFinal)

Papéis (Roles)

- Objetivo
 - Atribuir as mesmas restrições de acesso a um grupo de usuários
- Exemplo
 - Várias caixas de um banco (várias agências) tem permissão para creditar e debitar valores na conta dos clientes. Ao invés de dar permissão de inclusão, alteração e exclusão para cada um dos caixas que tem este direito, cria-se o papel **movimentação**

CREATE ROLE movimentacao

E dá-se a permissão ao papel

GRANT INSERT, UPDATE, DELETE **TO** movimentacao

Vincula todos os usuários ao papel

GRANT movimentacao **TO** joao, maria, jose

Exemplo Completo

- Suponha que o DBA crie 4 contas joao, jose, maria e marta
- Somente U1 deve criar relações no banco (privilégio de conta)
 - **GRANT** createTab **TO** joao
- Com essa autorização o usuário **joao** pode criar relações e terá TODOS os privilégios sobre elas
 - Suponha que **joao** criou as relações

Empregado (codEmp, nome, categoria, salario)

Projeto (#codProj, tipo, descricao)

ProjetoEmpregado (# codProj, # codEmp, dataInicial, dataFinal)

Exemplo Completo

- Suponha que **joao** quer dar ao usuário **jose** permissão para incluir e remover tuplas em **Empregado** e **Projeto**
 - **GRANT** INSERT, DELETE **ON** EMPREGADO, PROJETO **TO** jose
- Suponha que **joao** quer dar ao usuário **maria** permissão para recuperar tuplas em **Empregado** e seja capaz de PROPAGAR este privilégio
 - **GRANT** SELECT **ON** EMPREGADO **TO** maria **WITH GRANT OPTION**

Empregado (codEmp, nome, categoria, salario)
Projeto (#codProj, tipo, descricao)

Exemplo Completo

- Agora **maria** pode conceder privilégio de seleção para **marta** sobre a relação Empregado
 - **GRANT** SELECT **ON** EMPREGADO **TO** marta
 - Obs: **marta** não pode propagar este privilégio
- Suponha que **joao** queira revogar a permissão de **maria**
 - **REVOKE** SELECT **ON** EMPREGADO **FROM** maria

Empregado (codEmp, nome, categoria, salario)
Projeto (#codProj, tipo, descricao)

Exemplo Completo

- Suponha que **joao** queira dar ao usuário **maria** permissão apenas para consultar **empregados** que trabalhem no projeto AATOM

```
CREATE VIEW vEmpregadoProjeto as
SELECT e.codEmp, e.nome, e.categoria, e.salario
FROM empregado e
JOIN projetoEmpregado j ON e.codEmp=j.codEmp
JOIN projeto p ON j.codProj=p.codProj
WHERE p.descricao="AATOM"

- GRANT SELECT ON vEMPEGADOProjeto TO maria
```

Empregado (codEmp, nome, categoria, salario)

Projeto (codProj, tipo, descricao)

ProjetoEmpregado (# codProj, # codEmp, dataInicial, dataFinal)

Conceder todos os privilégios

- **GRANT** all **TO** {listaUsuários | public}



Medidas de Controle

- Controle de Acesso
- **Controle de inferência**
- Controle de fluxo
- Criptografia de dados

Controle de Inferência

- Objetivo
 - Evitar que consultas estatísticas permitam obter dados individuais de modo a proteger a privacidade dos indivíduos
- Exemplo
 - Utilizar as funções MIN, MAX, AVG para descobrir o salário de uma pessoa específica (quando a população especificada pela condição de seleção for pequena)



Controle de Inferência

- Técnicas

- Proibir consultas estatísticas quando o número de tuplas da população especificada pela condição de seleção for abaixo de um limiar
- Proibir sequência de consultas que se referem repetidamente à mesma população de tuplas
- Introduzir pequenas imprecisões ou ruídos nos resultados das consultas estatísticas



Medidas de Controle

- Controle de Acesso
- Controle de inferência
- **Controle de fluxo**
- Criptografia de dados



Controle de Fluxo

- Objetivo
 - Impedir que a informação contida em alguns objetos flua explícita ou implicitamente para objetos menos protegidos
- Exemplo
 - Impedir que um usuário obtenha indiretamente em um objeto Y o que não pode obter de maneira direta em um objeto X



Medidas de Controle

- Controle de Acesso
- Controle de inferência
- Controle de fluxo
- **Criptografia de dados**



Criptografia

- Definição
 - Conversão de dados para um formato que não pode ser facilmente entendido por pessoas não autorizadas
- Objetivo
 - Disfarçar a mensagem de modo que mesmo que ela seja obtida indevidamente, ela não seja revelada



Conceitos

- Texto cifrado
 - Dados criptografados (codificados)
- Tempo limpo
 - Dados inteligíveis que têm significado e podem ser lidos ou atuados sem a aplicação da descriptografia
- Criptografia
 - O processo de transformar texto limpo em texto cifrado
- Descriptografia
 - O processo de transformar texto cifrado de volta para o texto limpo



Como funciona

- Criptografia
 - Consiste em aplicar um **algoritmo de criptografia** aos dados usando alguma **chave de criptografia** pré-especificada
- Descriptografia
 - Os dados resultantes precisam ser **descriptografados** usando uma **chave de descriptografia** para recuperar os dados originais



Algoritmos de chave simétrica

- Ideias
 - A mesma chave secreta é utilizada para criptografar e descriptografar
 - Aplicação de operações em padrões de bits
- Desvantagem
 - Necessidade de compartilhar a chave secreta entre emissor e destinatário
- Observação
 - Quanto mais longa a chave, mais difícil de quebrar a criptografia



Algoritmos de chave pública (assimétrica)

- Ideia base
 - Duas chaves são utilizadas
 - Chave pública: pode ser transmitida de forma não segura
 - Chave privada: não é transmitida
 - Baseado em funções matemáticas



Infraestrutura de chave pública

- Texto limpo
 - Mensagem original
- Algoritmo de criptografia
 - Realiza diversas transformações no texto limpo
- Chaves pública
 - Utilizada para criptografar – (é divulgada)
- Chave privada
 - Utilizada para descriptografar (conhecida apenas pelo proprietário)
- Texto cifrado
 - É a mensagem misturada produzida como saída. Ela depende do texto limpo e da chave pública. Para uma mesma mensagem, duas chaves diferentes produzirão dois textos cifrados diferentes
- Algoritmo de descriptografia
 - Produz o texto limpo original a partir do texto cifrado e da chave privada



Apresentações

- GRUPO 01: Assinaturas digitais
- GRUPO 02: Certificados digitais
- GRUPO 03: Injeção de SQL – Tipos
- GRUPO 04: Formas de proteção

